SIE / ENTREGA FINAL / ANEXO F

Roles, permisos y seguridad

Política de permisos y controles existentes.

Control de documento	Detalle
Proyecto	MesaHelp · MVP académico de gestión de solicitudes
Versión del código	0.3.1 · candidata de cierre funcional (11/11/2026)
Tipo de entrega	Trabajo individual según asignación comunicada por docente
Autor / identificador	Hector Alejandro Garcés
Fecha	11 de noviembre de 2026
Estado	Validación local y GitHub Actions correctas; repositorio público

GitHub y GitHub Pages publicados. Instalación por tercero aún por verificar.

CORPORACIÓN UNIVERSITARIA AUTÓNOMA DEL CAUCA

Sistemas de Información Empresariales | Trabajo individual | Noviembre de 2026

Contenido

Contenido 2

1. Matriz de roles 3

2. Controles observables 3

3. Protección de datos y advertencias 3

1. Matriz de roles

Operación	Coordinador	Solicitante	Invitado
Crear ticket	Sí	Sí	Sí, sin cuenta
Listar tickets	Todos	Solo propios	No
Ver detalle	Todos	Solo propios	Solo propio con código
Cambiar estado	Sí	No	No
Agregar observación	Sí	No	No
Explorador + ordenar	Todos autorizados	Propios	No
Reportes / CSV	Todos autorizados	Propios	No
Ver seguimiento por código	No necesario	No necesario	Sí

2. Controles observables

- Hash de contraseñas con scrypt y sal individual.
- Sesiones con token aleatorio; almacenamiento de hash y vencimiento.
- CSRF en operaciones POST, validación de entrada y uso de SQL parametrizado.
- Comprobación de propiedad de tickets en consultas de detalle y listado, exportación y avisos Live.
- Código de invitados cifrado por hash, mostrado una sola vez; no aparece en CSV.
- Cookies HttpOnly, SameSite=Lax, Secure activable con HTTPS.
- CSP, nosniff y medidas sencillas de limitación de abuso por IP.

3. Protección de datos y advertencias

Solo utilizar datos de ejemplo en el paquete público. Excluir `data/`, `backups/`, `.env`, contraseñas, códigos de invitado y sesiones. La seguridad verificada es básica; hacer un despliegue público requiere controles adicionales y revisión del proxy.

No se ofrece recuperación de cuenta ni administración formal de usuarios para un entorno productivo.